www.technoma.com.py | #SomosTechnoma

Grupo Riquelme

Informe Técnico

Versión 2.0 - Preliminar



USO EXCLUSIVO Grupo Riquelme

DECLARATORIA DE CONFIDENCIALIDAD

El presente documento y todo su contenido es de carácter confidencial. TECHNOMA autoriza expresamente a los funcionarios de Grupo Riquelme que tengan injerencia directa en la evaluación de este documento, como también a los miembros activos de su Comité de Seguridad, a acceder al contenido de este documento con el propósito exclusivo de la evaluar el contenido del mismo por TECHNOMA SAECA. Las personas que accedan al contenido del presente documento aplicarán al menos las mismas buenas prácticas de cuidado de información confidencial que mantienen para la información confidencial de sus propias organizaciones, comprometiéndose a no usar el documento ni su contenido para ningún otro propósito que el establecido en esta declaratoria, ni compartirlo de forma completa ni parcial con personas no autorizadas.

INFORME DE INCIDENTE DE CIBERSEGURIDAD

Para: Dirección Ejecutiva y Presidencia del Grupo Riquelme
Elaborado por: SOC / CSIRT Technoma - Ivan Centurion
Estado de la investigación: En curso (Confidencial) - Actualizada a 26/06/2026

Resumen

El presente documento expone el estado de situación, las acciones de contención implementadas y el análisis preliminar tras el ataque cibernético perpetrado contra el ecosistema tecnológico del Grupo Riquelme. El incidente ha sido atribuido al grupo de cibercriminales conocido como **NightSpire**. El ataque provocó la paralización temporal de una parte de las operaciones de seguridad y de negocio del grupo, afectando de manera crítica las copias de seguridad del sistema de gestión interna (ERP). La investigación cruzada ha permitido identificar con precisión el vector de acceso inicial, el cual se asocia a la campaña global de recolección de credenciales conocida como FortiBleed.

Perfil del atacante

Para entender la naturaleza de la crisis, es fundamental conocer los objetivos y el comportamiento habitual de la amenaza detectada:

- NightSpire es un grupo cibercriminal de alcance global motivado estrictamente por fines económicos. No realizan ataques dirigidos por motivos políticos, sino que seleccionan a sus víctimas de forma oportunista.
- Su estrategia consiste en ingresar a la red, extraer información confidencial de la empresa corporativa y, posteriormente, activar un programa de cifrado que bloquea el acceso a los sistemas. Exigen un rescate económico bajo la amenaza de publicar los datos robados en un sitio web oculto (Dark Web) si la organización no paga.
- Suelen atacar sectores clave (como manufactura, logística y retail) buscando organizaciones donde la interrupción operativa genere una presión financiera inmediata que fuerce el pago. Tienen como práctica común buscar y destruir o cifrar las copias de seguridad (backups) para eliminar la capacidad de recuperación autónoma de la empresa.

Desarrollo de eventos

La cronología de los eventos y las acciones de mitigación inmediata se detallan a continuación:

Detección y alerta

El ataque se encontraba en una fase silenciosa de preparación desde hace un tiempo atrás. Las alertas críticas saltaron el pasado **viernes en horas de la noche (aproximadamente a partir de las 9:00 p.m.)**, cuando las áreas técnicas identificaron anomalías severas que derivaron en la paralización parcial de procesos operativos y de seguridad en varias empresas del grupo.

Alcance del evento

El Grupo Riquelme distribuye sus datos en varios datacenters; la afectación se concentró específicamente en 1 de ellos, ubicado en el servicio de housing de la empresa Tigo. Durante la inspección técnica, se analizaron dos servidores con el sistema operativo Windows Server 2008 y Windows Server 2008 R2. En estos activos se encontraron y recolectaron los fragmentos de código y artefactos maliciosos pertenecientes a la herramienta de secuestro de datos de NightSpire. Estos servidores actuaron como uno de los puntos críticos de ejecución del cifrado dentro de la red local.

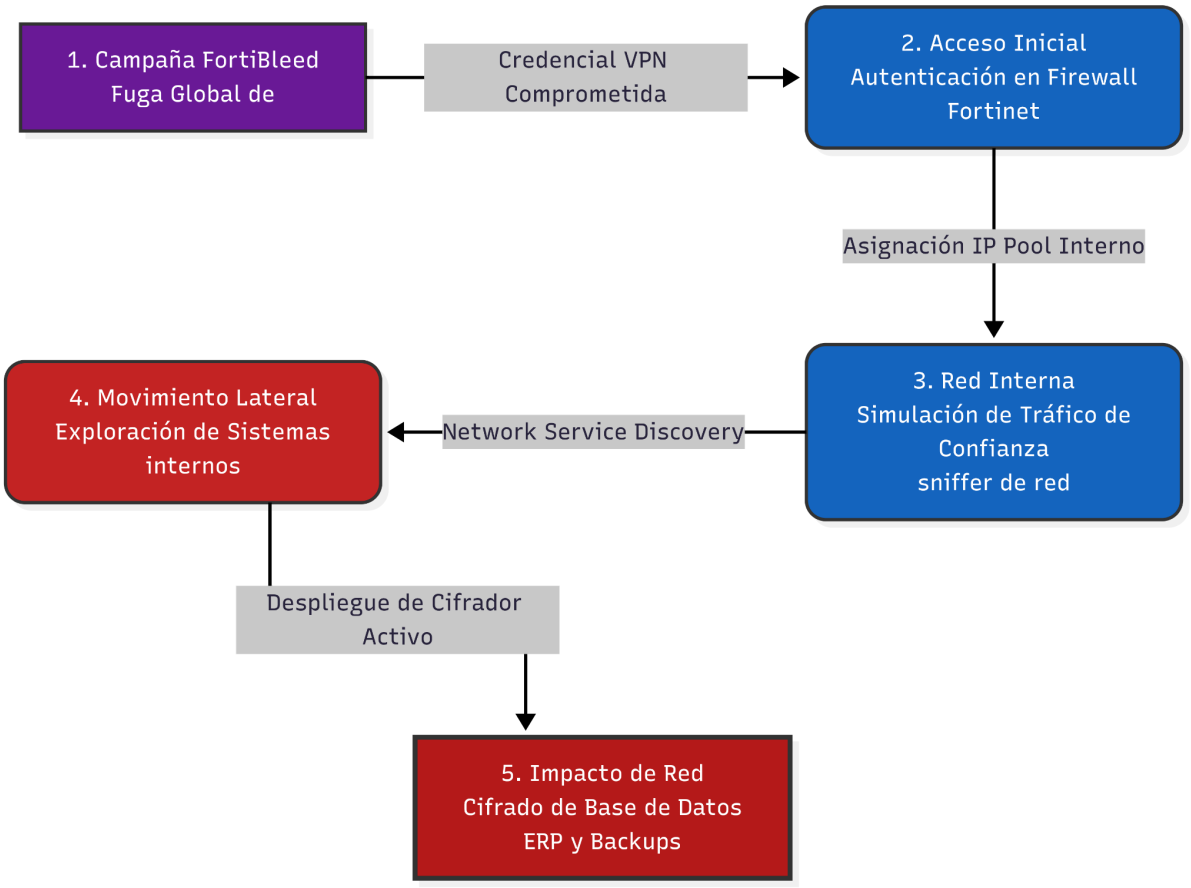
Recolección de evidencias

Durante la inspección técnica en el datacenter de Tigo, se analizaron **dos servidores con el sistema operativo Windows Server 2008 y Windows Server 2008 R2**. En estos activos se encontraron y recolectaron los fragmentos de código y artefactos maliciosos pertenecientes a la herramienta de secuestro de datos de NightSpire. Estos servidores actuaron como uno de los puntos críticos de ejecución del cifrado dentro de la red local. Se detectaron las IP orígenes de los accesos por parte de los atacantes para acceder a los servidores mencionados. Esto confirmó inicialmente que el actor de la amenaza operaba desde un segmento interno de confianza antes de iniciar la ejecución del ransomware.

USO EXCLUSIVO Grupo Riquelme

Investigación cruzada (vector de acceso)

Para determinar el mecanismo por el cual el atacante obtuvo direccionamiento IP interno sin activar alertas perimetrales, se correlacionaron los hallazgos forenses con plataformas externas de Inteligencia de Amenazas.



- Las consultas externas revelaron que el dominio principal del grupo (gruporiquelme.com) registraba una credencial de Fortinet comprometida dentro del dataset de la campaña global FortiBleed.
    - La campaña FortiBleed es una operación de ciberataque activa y global que funciona bajo el siguiente mecanismo técnico:
        - Se trata de una campaña automatizada orientada a objetivos a escala mundial que rastrea e identifica de forma masiva firewalls Fortinet y gateways de VPN expuestos a internet.
        - Aprovechando vulnerabilidades en el firmware de los dispositivos, los atacantes extraen credenciales de acceso (usuarios y contraseñas) y registros de sesiones VPN directamente de los equipos comprometidos, alimentando de

USO EXCLUSIVO Grupo Riquelme

forma continua una base de datos de atacantes con nuevos dispositivos vulnerados.

- Toda la información recolectada se centraliza en un repositorio masivo de brechas de seguridad que expone a más de 86.000 dispositivos de firewalls comprometidos globalmente. Este dataset se encuentra disponible en repositorios de cibercriminales, permitiendo que grupos de ransomware compren o utilicen estos accesos válidos para ingresar a las redes internas de sus víctimas sin necesidad de forzar el perímetro.

- Se sospecha que el grupo NightSpire utilizó una credencial válida de VPN / acceso administrativo obtenida a través de FortiBleed. Al autenticarse de forma legítima contra el firewall perimetral, el gateway de la empresa le asignó al atacante una dirección IP interna del pool corporativo. Esto le permitió evadir los controles perimetrales iniciales al simular tráfico remoto autorizado y explica por qué los logs mostraban IPs de origen internas del grupo.
- Una vez posicionado dentro del segmento interno confiable, el atacante ejecutó tácticas de descubrimiento de servicios de red (Network Service Discovery) para mapear la infraestructura distribuida en los datacenters. Al identificar vulnerabilidades de menor dificultad de explotación en el datacenter de Tigo (servidores Windows Server 2008 heredados), los cibercriminales procedieron a iniciar la inutilización de los backups a través del despliegue del software de cifrado.

Estado actual de la recuperación y datos afectados

El estado de la información y los esfuerzos de ingeniería inversa se resumen en los siguientes puntos:

- El impacto más crítico radica en que el ransomware logró alcanzar y cifrar las copias de seguridad de un sistema ERP interno, cifrando su base de datos y copias de seguridad.
- A la fecha, **no existe una herramienta pública ni gratuita en el mercado global** capaz de revertir el cifrado de esta variante de NightSpire.
- El equipo de Technoma ha logrado asegurar y aislar una muestra viva del programa cifrador utilizado en el ataque. En este momento, nuestros especialistas se encuentran realizando análisis de su estructura para identificar posibles puntos débiles en su programación. Sin embargo, este proceso requiere **más tiempo de análisis** para determinar con certeza si es viable

USO EXCLUSIVO Grupo Riquelme

diseñar una herramienta de descifrado propia que ayude a rescatar los archivos afectados sin ceder a la extorsión.

Diagnóstico

El análisis preliminar de la infraestructura del Grupo Riquelme denota las siguientes conclusiones estratégicas:

- Si bien el Grupo Riquelme cuenta con herramientas de protección avanzadas como sistemas EDR y XDR (Sophos, ThreatDown, Firewalls), la presencia de activos obsoletos expuestos (Windows Server 2008) generó una brecha tecnológica significativa. Los atacantes aprovecharon la confianza del acceso por VPN para evadir las defensas modernas y comprometer los sistemas desprotegidos.
- Para detectar y contener definitivamente esta amenaza y evitar réplicas, el grupo requiere de manera urgente el fortalecimiento y la continuidad de servicios especializados de ciberseguridad que ejecuten un monitoreo especializado, remediación de vulnerabilidades perimetrales y reajuste de las políticas de red.
- **Al día de la fecha, el grupo cibercriminal ha reclamado la autoría intelectual del ataque, y el estado del mismo ha pasado a ser de conocimiento público.**
    - https://x.com/FalconFeedsio/status/2070261277105266725
    - https://x.com/TMRansomMon/status/2070301528682910016

Acciones Inmediatas de Remediación Perimetral y Sistemas internos (Nuevas)

- Forzar la desconexión inmediata y la terminación de todas las sesiones de VPN SSL activas en los firewalls de la corporación.
- Cambiar de forma obligatoria las contraseñas de todas las cuentas con acceso a la VPN y de las cuentas de administración de los dispositivos Fortinet, Active directory, usuarios de sistemas, ya que los atacantes podrían haber contado con la capacidad de utilizar el módulo de sniffer o capturadores de paquetes del equipo de borde por cual hubieron ingresado, los mismos pudieron haber capturado datos de aplicaciones en tránsito.
- Activar la autenticación de múltiples factores (MFA) sin excepciones para cualquier acceso remoto o de administración.
- Asegurar que los dispositivos Fortinet estén actualizados a las versiones de firmware que mitigan la extracción y descifrado offline de credenciales

mediante algoritmos robustos de hashing.

Recomendaciones

- No reconectar los sistemas afectados a la red corporativa general hasta que Technoma certifique que están limpios.
- Elevar al máximo las restricciones de acceso en los otros 2 datacenters remanentes del grupo.
- Permitir que el equipo técnico agote las vías de análisis de la muestra antes de tomar cualquier decisión de carácter financiero o de negociación con el grupo criminal.
- Resguardar los datos cifrados a la espera de que surja un descifrador, o el laboratorio de Technoma pueda proveer una herramienta de descifrado.
- Desplegar sensores de red especializados en la detección temprana de anomalías, movimientos laterales por parte de actores maliciosos.
- Realizar copias de seguridad en sitios alternativos a los datacenter para resguardar los datos de los sistemas actuales no vulnerados.

USO EXCLUSIVO Grupo Riquelme

Anexo: Mecanismo de intrusión y vulnerabilidades de FortiBleed

La campaña FortiBleed, activa desde al menos febrero de 2026, no opera como un ataque masivo de explotación de vulnerabilidades de "día cero" (*zero-day*), sino como una operación híbrida altamente automatizada que se ejecuta en dos etapas auto-sostenibles.

La Vulnerabilidad vinculada (CVE-2026-24858)

La campaña principalmente consiste en la reutilización de credenciales, las investigaciones identifican un fallo crítico específico dentro del ecosistema Fortinet que facilitó el acceso inicial en ciertos escenarios:

- **CVE-2026-24858:** Se trata de una vulnerabilidad crítica de **bypass de autenticación SAML en FortiCloud SSO**.
    - https://www.fortiguard.com/psirt/FG-IR-26-060
- **Severidad:** Cuenta con una puntuación **CVSS de hasta 9.8**, catalogada como Crítica.
- **Impacto:** Fue divulgada por Fortinet en enero de 2026 y permitió a los atacantes evadir los procesos de autenticación y comprometer accesos perimetrales en un subconjunto de las organizaciones afectadas.

Ciclo de infección

La infraestructura utilizada por la campaña de FortiBleed se encuentra automatizada y distribuida en más de 260 servidores en diferentes regiones, la cual se gestiona a sí misma mediante el siguiente ciclo técnico:

- **Etapa 1 - Reutilización de Credenciales**
    - Los atacantes compilaron listados masivos de usuarios y contraseñas provenientes de filtraciones previas de Fortinet y registros de malware de tipo *infostealer*. Mediante herramientas automatizadas que operan de forma ininterrumpida, probaron estas combinaciones contra las interfaces de administración expuestas en internet (principalmente puertos **443, 4443, 8443 y 10443**).
- **Etapa 2 - Adquisición de datos**
    - Una vez que los procesos automatizados de FortiBleed lograran autenticarse exitosamente utilizando una credencial válida, el dispositivo FortiGate se transforma en un **puesto de escucha**. A partir

USO EXCLUSIVO Grupo Riquelme

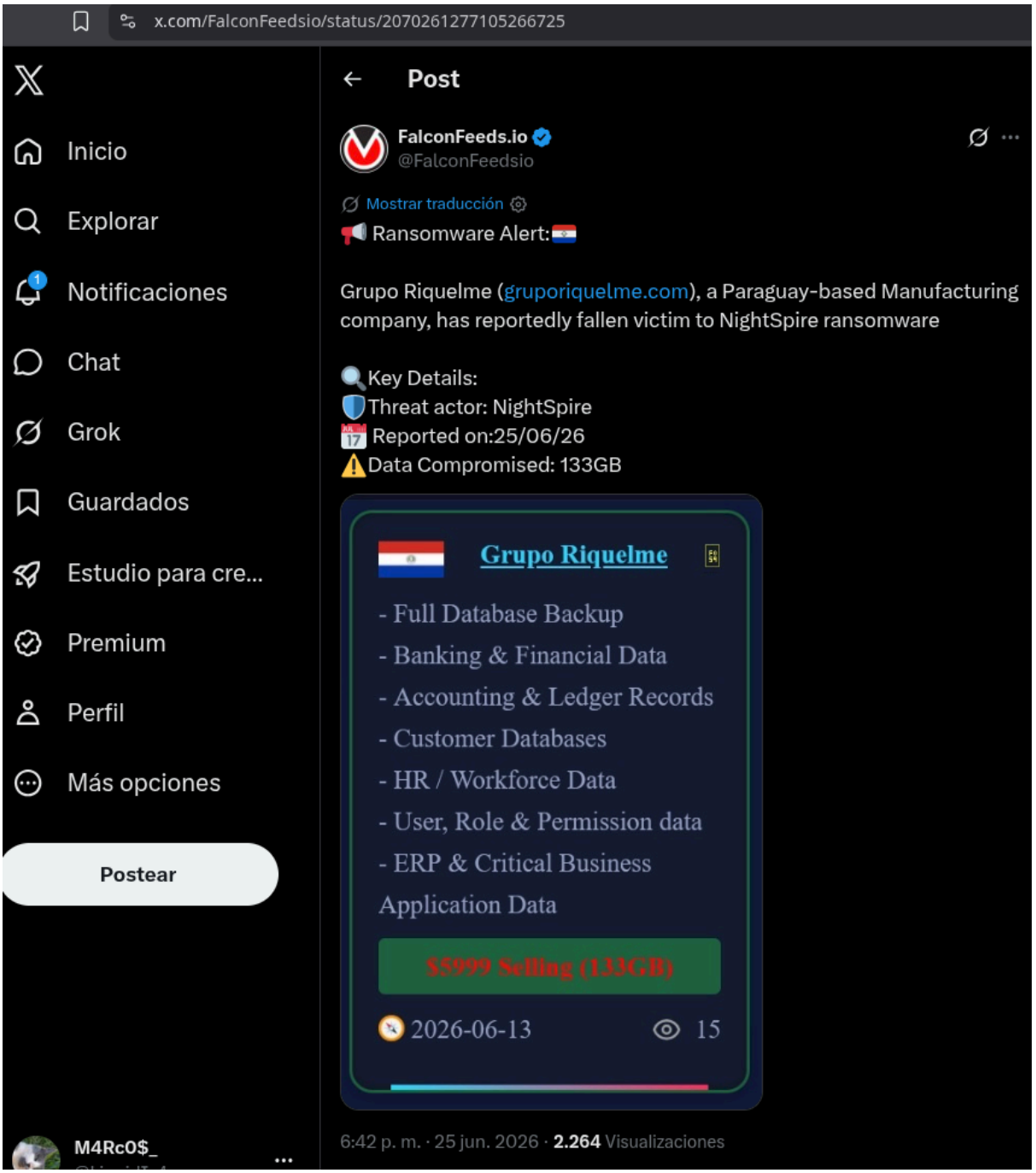
de ese momento, los atacantes monitorean pasivamente todo el tráfico de la VPN SSL que transita por el equipo, descubren la red interna de la organización y mapean objetivos de alto valor.

- **Persistencia**
  - Las nuevas credenciales de los empleados legítimos capturadas durante esta interceptación pasiva se reutilizan automáticamente en los escáneres de la campaña, expandiendo y validando el acceso a la red interna de forma perpetua.

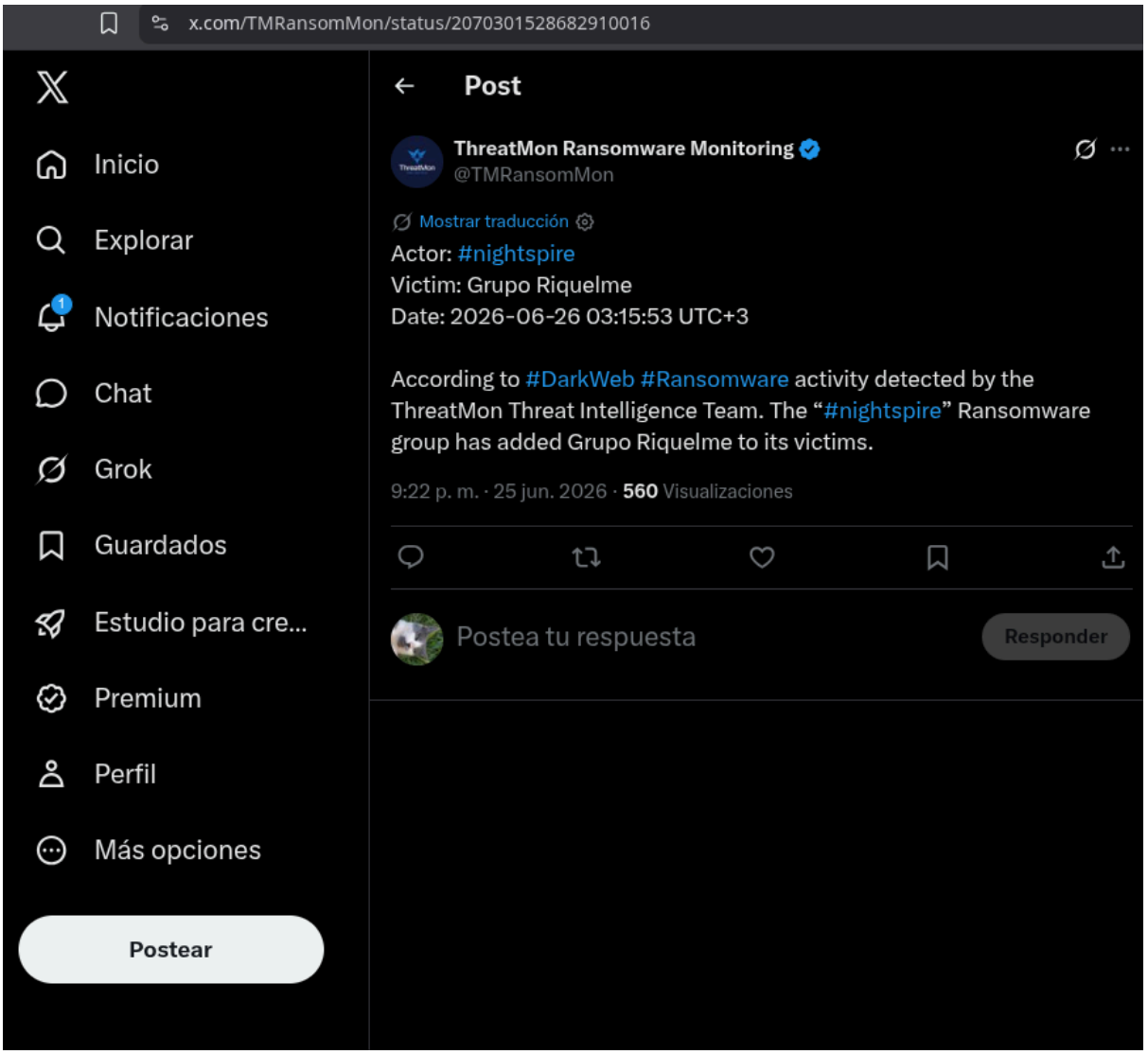
Esto podría reforzar la hipótesis de que el perímetro se vio vulnerado. Si la organización se encontraba listada en el dataset de más de 86,644 dispositivos comprometidos, los atacantes de NightSpire simplemente extrajeron o compraron el acceso válido generado por la infraestructura de FortiBleed, permitiéndoles iniciar sesión por VPN y camuflarse bajo una dirección IP interna legítima para proceder al movimiento lateral.

USO EXCLUSIVO Grupo Riquelme

Anexo Imágenes



USO EXCLUSIVO Grupo Riquelme



USO EXCLUSIVO Grupo Riquelme